

Security+ 1.2 · Deception & Disruption

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 1.2 — Deception & Disruption**
(4:30) · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Isca e engana: honeypot (máquina falso), honeynet (rede de honeypots), honeyfiles (arquivo-isca), DNS sinkhole (redireciona domínio malicioso pra nada), false azure (serviço que finge ser cloud). Detecta e estuda o atacante.

Highlights que a prova cobra

- Honeypot = alvo falso: parece real, é monitorado
- Honeyfile: documento-isca com beacon — dispara alerta ao abrir
- DNS sinkhole = envia C2 pra IP nulo e LOGA quem tentou

Dicas de prova & Cenários Típicos

- 'appears vulnerable but is monitored' = honeypot
- 'redirects malicious domain traffic' = sinkhole

Cenário clássico de exame: Cenário típico: 'empresa coloca servidor falsamente vulnerável pra detectar e estudar intrusão' → honeypot.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 1.2 — Deception & Disruption)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Sistema-isca que finge ser vulnerável pra atrair e estudar atacantes:

- A)** Honeypot
- B)** DMZ
- C)** Bastion host
- D)** Jump box

2. No modelo Zero Trust, qual é o princípio fundamental?

- A)** Confiar sempre em usuários internos
- B)** Confiar mas verificar
- C)** Nunca confiar, sempre verificar
- D)** Confiar apenas em VPNs

3. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Honeypot = alvo falso: parece real, é monitorado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Honeypot = alvo falso: parece real, é monitorado...

4. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Honeyfile: documento-isca com beacon — dispara alerta ao abrir'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Honeyfile: documento-isca com beacon — dispara alerta ao abrir...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'DNS sinkhole = envia C2 pra IP nulo e LOGA quem tentou'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: DNS sinkhole = envia C2 pra IP nulo e LOGA quem tentou...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'appears vulnerable but is monitored' = honeypot'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'appears vulnerable but is monitored' = honeypot...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'redirects malicious domain traffic' = sinkhole'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'redirects malicious domain traffic' = sinkhole...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'empresa coloca servidor falsamente vulnerável pra detectar e estudar intrusão' → honeypot.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário típico: 'empresa coloca servidor falsamente vulnerável pra detectar...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Honeypot = alvo falso: parece real, é monitorado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Honeypot = alvo falso: parece real, é monitorado...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Honeyfile: documento-isca com beacon — dispara alerta ao abrir'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Honeyfile: documento-isca com beacon — dispara alerta ao abrir...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — Honeypot.

✓ **Por que está certa:** Honeypot é um sistema-isca projetado para parecer vulnerável e atrair atacantes, com o objetivo de estudar suas táticas, técnicas e procedimentos (TTPs), desviar atenção de sistemas reais e coletar inteligência sobre ameaças. Pode ser de baixa interação (simula serviços) ou alta interação (sistema real isolado). É um controle de segurança proativo e de detecção, conforme o objetivo SY0-701 3.2 (implementação de segurança) e 4.8 (monitoramento e detecção). A questão descreve exatamente um sistema-isca que finge ser vulnerável para atrair e estudar atacantes, que é a definição de honeypot.

✗ **Por que as outras estão erradas:**

- **DMZ:** DMZ (Zona Desmilitarizada) é uma sub-rede física ou lógica que fica entre a rede interna confiável e a rede externa não confiável (ex.: Internet). Ela hospeda serviços públicos (web, e-mail, DNS) para evitar que ataques externos alcancem diretamente a rede interna. A DMZ não é um sistema-isca; é um segmento de rede projetado para expor serviços controladamente. Não finge ser vulnerável nem tem como objetivo atrair e estudar atacantes. A questão pede um sistema-isca, não uma arquitetura de segmentação.
- **Bastion host:** Bastion host é um sistema fortemente protegido e exposto a uma rede não confiável, geralmente atuando como ponto de entrada único para administração remota ou como proxy. Ele é endurecido (hardened) e monitorado, mas não é uma isca; é um ponto de defesa. Seu propósito é ser seguro, não parecer vulnerável. A questão descreve um sistema que finge ser vulnerável para atrair atacantes, o que é o oposto do bastion host, que é projetado para ser o mais seguro possível.
- **Jump box:** Jump box (ou jump server) é um sistema intermediário usado para acessar e administrar dispositivos em uma rede segregada, como uma DMZ ou rede interna. Ele centraliza o acesso administrativo, aplica autenticação forte e registra atividades. Não é uma isca; é uma ferramenta de controle de acesso. Não finge ser vulnerável nem tem como objetivo estudar atacantes. A questão pede um sistema-isca, não um ponto de salto administrativo.

2) C — Nunca confiar, sempre verificar.

✓ **Por que está certa:** A alternativa correta é 'Nunca confiar, sempre verificar'. O modelo Zero Trust, conforme definido pelo NIST SP 800-207 e abordado no CompTIA Security+, baseia-se no princípio de que nenhuma entidade (usuário, dispositivo ou aplicação) é confiável por padrão, independentemente de estar dentro ou fora do perímetro da rede corporativa. A arquitetura Zero Trust exige verificação contínua de identidade, contexto e autorização para cada acesso a recursos, utilizando autenticação multifator (MFA), microssegmentação, políticas de menor privilégio e monitoramento constante. O lema 'nunca confiar, sempre verificar' resume a mudança de paradigma: a confiança não é implícita, mas concedida dinamicamente com base em políticas e evidências.

✗ **Por que as outras estão erradas:**

- **Confiar sempre em usuários internos:** Esta alternativa descreve o modelo tradicional de segurança baseado em perímetro, onde se assume que tudo dentro da rede é confiável. Esse é exatamente o oposto do Zero Trust. O modelo de confiança implícita em usuários internos é vulnerável a ameaças internas, movimentação lateral e comprometimento de credenciais. O Zero Trust surgiu justamente para eliminar essa suposição, tratando redes internas como potencialmente hostis e exigindo verificação para todos os acessos, independentemente da localização.
- **Confiar mas verificar:** Esta alternativa é uma variação do modelo tradicional de confiança condicional, mas não representa o Zero Trust. A frase 'confiar mas verificar' sugere que a confiança

é o estado inicial, e a verificação é um complemento. No Zero Trust, a confiança nunca é presumida; a verificação é o ponto de partida e ocorre continuamente. A abordagem 'confiar mas verificar' ainda mantém uma suposição de confiança que pode ser explorada, enquanto o Zero Trust exige que cada solicitação seja autenticada e autorizada antes de qualquer acesso.

- *Confiar apenas em VPNs*: Esta alternativa reduz o Zero Trust a uma única tecnologia de acesso remoto. VPNs tradicionais criam um túnel criptografado e, uma vez autenticado, o usuário geralmente recebe acesso amplo à rede interna, o que viola o princípio de menor privilégio e verificação contínua. O Zero Trust não se limita a VPNs; ele envolve microsegmentação, autenticação forte, políticas granulares e monitoramento contínuo. Confiar apenas em VPNs mantém o modelo de confiança baseado em perímetro, que é insuficiente para proteger contra ameaças modernas e não atende aos requisitos do Zero Trust.

3) D — Implementar a solução correspondente: Honeypot = alvo falso: parece real, é monitorado....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): Honeypot = alvo falso: parece real, é monitorado.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: Honeyfile: documento-isca com beacon — dispara alerta ao abrir....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): Honeyfile: documento-isca com beacon — dispara alerta ao abrir.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) A — Implementar a solução correspondente: DNS sinkhole = envia C2 pra IP nulo e LOGA quem tentou....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): DNS sinkhole = envia C2 pra IP nulo e LOGA quem tentou.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: 'appears vulnerable but is monitored' = honeypot....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): 'appears vulnerable but is monitored' = honeypot.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: 'redirects malicious domain traffic' = sinkhole....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): 'redirects malicious domain traffic' = sinkhole.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: Cenário típico: 'empresa coloca servidor falsamente vulnerável pra detectar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): Cenário típico: 'empresa coloca servidor falsamente vulnerável pra detectar e estudar intrusão' → honeypot..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola

frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: Honeypot = alvo falso: parece real, é monitorado....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): Honeypot = alvo falso: parece real, é monitorado.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: Honeyfile: documento-isca com beacon — dispara alerta ao abrir....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): Honeyfile: documento-isca com beacon — dispara alerta ao abrir.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.